2026

Plan de Respuesta Ante Incidentes

CNO IV: SEGURIDAD INFORMÁTICA

ALEJANDRO GARCÍA MORALES

1. Propósito, Alcance y Clasificación (Criterio PR02-31)

1.1 Propósito

El Plan tiene por objeto dotar a INTERAFAS de una capacidad formal de respuesta a incidentes de ciberseguridad, que permita detectar, analizar, contener, erradicar y recuperar operaciones de forma oportuna ante eventos que amenacen la confidencialidad, integridad o disponibilidad de sus sistemas de información y de sus procesos de control industrial, minimizando el impacto operativo, financiero, legal, reputacional y, de manera prioritaria, el riesgo a la seguridad física derivado de la naturaleza de infraestructura crítica hídrica de la organización.

1.2 Alcance

El Plan aplica a la totalidad de los activos de información y de control industrial de INTERAFAS, incluyendo —sin limitarse a— el portal institucional y sus APIs ciudadanas, las bases de datos transaccionales, la infraestructura de red perimetral e interna, y el entorno operacional (HMI, gateways de telemetría tipo RTU-GW-07, controladores lógicos programables como el PLC Saint Louis, y demás activos de la zona de bombeo primario). Aplica a todo el personal de INTERAFAS, así como a terceros, proveedores y contratistas con acceso a dichos activos. Quedan fuera del alcance directo del Plan los incidentes de naturaleza exclusivamente física sin componente cibernético (p. ej., fallas mecánicas no provocadas por manipulación de parámetros digitales), los cuales se atienden bajo los protocolos ordinarios de mantenimiento, sin perjuicio de que puedan derivar en la activación del Plan si se identifica una causa cibernética subyacente.

1.3 Concepto de Incidente de Ciberseguridad para INTERAFAS

Para efectos de este Plan, se entiende por incidente de ciberseguridad todo evento confirmado o sospechado que viole las políticas de seguridad de la información de INTERAFAS, las prácticas de uso aceptable, o que comprometa la confidencialidad, integridad o disponibilidad de un activo de información o de control industrial, incluyendo de manera enunciativa mas no limitativa: el acceso no autorizado a sistemas o datos; la explotación de una vulnerabilidad técnica con fines de escalada de privilegios o exfiltración de información; la alteración no autorizada de código, configuraciones o parámetros de proceso; la introducción de código malicioso; la denegación de servicio; y cualquier acceso, modificación o interacción no autorizada con los sistemas de la zona operacional (OT).

1.4 Criterios de Severidad

La clasificación de severidad del Plan se basa en una adaptación simplificada del Esquema Nacional de Severidad de Incidentes Cibernéticos (NCISS) utilizado por CISA, evaluando el impacto funcional, el impacto en la información y la recuperabilidad del incidente.

Nivel	Impacto Funcional	Impacto en la Información	Recuperabilidad	Ejemplo (INTERAFAS-LAB)
Bajo (Nivel 1)	Nulo o mínimo; sin afectación perceptible a servicios.	Ninguna exposición confirmada de datos sensibles.	Regular (horas, con recursos ordinarios).	Hallazgo de archivo residual sin evidencia de explotación activa (Retos 01, 02, 04, 05).
Medio (Nivel 2)	Degradación parcial de un servicio o módulo no crítico.	Exposición limitada de datos de un número acotado de usuarios.	Regular a Suplementada (horas a 1-2 días).	IDOR/BOLA confirmado con acceso a expedientes individuales (Retos

				03, 11, 12) o Stored XSS (Reto 08).
Alto (Nivel 3)	Afectación significativa a un servicio crítico para la ciudadanía; sin afectación física.	Exposición masiva o estructural de datos (padrón completo) o compromiso de credenciales privilegiadas.	Suplementada (días, con apoyo de terceros especializados).	Escalada de privilegios (Reto 06), SQLi confirmada (Reto 07) o pivote hacia la frontera OT (Retos 15, 16).
Crítico / Emergencia (Nivel 4)	Pérdida total o riesgo inminente de pérdida de un servicio esencial, con posible afectación física.	Compromiso de integridad de sistemas de control industrial.	No recuperable con recursos existentes; requiere activación de continuidad de negocio.	Alteración de pressure_setpoint_bar y CATASTROPHIC STATE en el proceso de bombeo (Retos 18, 19, 20).

1.5 Prioridades de Respuesta

- Primera prioridad: proteger la vida humana y la seguridad física, suspendiendo o aislando de inmediato cualquier proceso de control industrial que se encuentre bajo manipulación no autorizada.
- Segunda prioridad: proteger la confidencialidad de la información de usuarios y la integridad de los sistemas críticos para la continuidad del servicio de agua potable.
- Tercera prioridad: preservar evidencia técnica para fines forenses, de cumplimiento regulatorio y de eventual persecución legal, sin que ello retrase las acciones de las dos prioridades anteriores.
- Cuarta prioridad: restablecer la operación normal de los sistemas afectados en el menor tiempo posible, una vez contenido y erradicado el incidente.
- Quinta prioridad: minimizar el impacto reputacional, financiero y legal para la organización, en coordinación con el Plan de Comunicación de Crisis (04.ApellidosNombre_PlanComunicacionCrisis).

1.6 Condiciones de Activación del Plan

El Plan se activa formalmente cuando se cumple al menos una de las siguientes condiciones: (i) el monitoreo de seguridad (SIEM, IDS/IPS, alertas de aplicación) genera una alerta clasificada como incidente confirmado o sospechado de Nivel 2 o superior conforme al numeral 1.4; (ii) un usuario interno o externo reporta, a través de los canales oficiales del numeral 3.4, un comportamiento anómalo que, tras el triage inicial (numeral 4.1), se confirma como incidente; (iii) se detecta actividad anómala en la telemetría del proceso de bombeo (presión, caudal, estado de alarmas) sin orden de trabajo de mantenimiento asociada; o (iv) se recibe notificación de un tercero (proveedor, autoridad, investigador de seguridad) sobre un posible compromiso de los sistemas de INTERAFAS. La activación formal corresponde al Líder del CSIRT, quien convoca al equipo conforme al numeral 2 y notifica a la Alta Dirección dentro de los primeros 30 minutos para incidentes Nivel 3 o 4.

2. Roles y Responsabilidades (Criterio PR02-32)

La respuesta a incidentes de INTERAFAS se organiza mediante un Equipo de Respuesta a Incidentes de Seguridad Informática (CSIRT, por sus siglas en inglés), de carácter interno, con capacidad de convocar apoyo externo especializado cuando la severidad del incidente lo requiera.

Rol	Titular / Área	Funciones Principales
Líder del CSIRT (Incident Commander)	Jefatura de Seguridad de la Información	Declara y des-declara la activación del Plan, coordina al equipo técnico, autoriza acciones de contención de alto impacto y es el punto único de mando durante el incidente.
Analistas de Seguridad / Respondedores Técnicos (IT)	Equipo de Ciberseguridad / Administración de Sistemas	Ejecutan el triage, el análisis técnico, la contención y la erradicación en los sistemas de información (portal, bases de datos, red corporativa).
Ingeniero(a) de Control / Respondedor OT	Dirección de Operación Hidráulica — Automatización y Control	Evalúa el estado real de los activos de control industrial, autoriza y ejecuta acciones de contención en la zona OT (aislamiento de PLC/HMI, reversión de setpoints) bajo el principio de seguridad física ante todo.
Administrador(a) de Infraestructura / Redes	Área de Tecnologías de la Información	Ejecuta bloqueos perimetrales, segmentación de red, preservación de logs de infraestructura y restauración de servicios.
Alta Dirección (Patrocinador Ejecutivo)	Dirección General	Autoriza decisiones de alto impacto operativo o financiero (p. ej., suspender un servicio público), y rinde cuentas ante el Consejo Directivo y autoridades.
Enlace Jurídico	Dirección de Asuntos Jurídicos	Determina obligaciones de notificación regulatoria, evalúa implicaciones legales de las acciones de respuesta y resguarda la cadena de custodia desde la perspectiva probatoria.
Enlace de Comunicación de Crisis	Dirección de Comunicación Social e Imagen Institucional	Activa y ejecuta el Plan de Comunicación de Crisis (04.ApellidosNombre_PlanComunicacionCrisis) en coordinación con el Líder del CSIRT.
Terceros Especializados (On-Call)	Proveedor forense externo / Fabricante del gateway RTU / ISP	Brindan apoyo especializado en análisis forense digital, análisis de firmware/ICS y mitigación a nivel de proveedor de conectividad, bajo acuerdos de nivel de servicio (SLA) preestablecidos.
Oficial de Protección de Datos / Cumplimiento	Área de Transparencia y Protección de Datos Personales	Evalúa el impacto a datos personales y coordina la notificación a titulares y autoridades conforme a la normatividad aplicable.

La matriz de activación de terceros, los datos de contacto 24/7 del CSIRT y los acuerdos de confidencialidad con proveedores forenses se mantienen en un anexo de contactos de emergencia, actualizado trimestralmente por el Líder del CSIRT.

3. Preparación, Detección y Reporte (Criterio PR02-33)

3.1 Mecanismos de Preparación

- Mantenimiento de un inventario actualizado de activos IT/OT, incluyendo endpoints expuestos, APIs y dispositivos de control (RTU-GW-07, PLC Saint Louis, HMI).
- Hardening periódico conforme a los dictámenes de mitigación del Informe Técnico de Seguridad Ofensiva (deshabilitar listado de directorios, eliminar archivos .bak/.zip residuales, forzar consultas preparadas, validar límites de ingeniería, entre otros).
- Respaldo periódico y verificado de configuraciones, bases de datos y firmware de referencia (golden image) de los dispositivos de control, almacenados fuera de línea.

- Capacitación y simulacros (tabletop exercises) del CSIRT y del personal operativo, incluyendo al menos un ejercicio anual que contemple un escenario de convergencia IT/OT.
- Disponibilidad previa de herramientas forenses, kits de recolección de evidencia (write-blockers, almacenamiento estéril) y plantillas de bitácora de incidentes.
- Acuerdos de nivel de servicio vigentes con terceros especializados en forensia digital y en el fabricante/integrador del gateway RTU-GW-07.

3.2 Fuentes de Detección

Fuente	Tipo de Señal que Aporta
Logs del servidor web (Apache) y de la aplicación PHP	Solicitudes anómalas a rutas sensibles, enumeración de archivos (.bak, .old, .zip), errores no controlados (UnhandledMatchError), patrones de Path Traversal.
Logs de base de datos (MariaDB)	Consultas con sintaxis inusual, picos de latencia asociados a inferencia booleana, accesos a information_schema fuera de horario de mantenimiento.
Sistema de Detección/Prevención de Intrusos (IDS/IPS)	Firmas de escaneo, intentos de bypass de cabeceras (X-Forwarded-For), tráfico hacia/desde la subred operacional 10.24.60.0/24 no autorizado.
Telemetría y alarmas del Centro de Operaciones (SCADA/HMI)	Variación de pressure_setpoint_bar fuera del rango de ingeniería (2.5–5.5 bar), incremento anómalo de caudal, saturación de alarmas, caída de disponibilidad.
Monitoreo de integridad de archivos (FIM)	Alteración no autorizada de código fuente PHP, manifiestos de build o paquetes de firmware.
Reportes ciudadanos / mesa de ayuda	Quejas sobre acceso indebido a su información, comportamiento inusual del portal (p. ej., scripts que se ejecutan al ver un reporte).
Inteligencia de fuentes abiertas (OSINT) y monitoreo de medios	Publicaciones en "Pulso Metropolitano" o redes sociales que referencian un posible incidente antes de su detección interna.

3.3 Recepción de Alertas y Registro

Toda alerta generada por las fuentes del numeral 3.2, así como todo reporte recibido por los canales del numeral 3.4, se registra de manera obligatoria en el Sistema de Gestión de Tickets de Seguridad de INTERAFAS, generando un folio único de incidente (formato INC-AAAA-NNNN) que acompaña el caso durante todo su ciclo de vida, desde la detección hasta el cierre post-incidente (numeral 10).

3.4 Canales Oficiales para Reportar Incidentes

- Línea telefónica de seguridad 24/7 del CSIRT (atención inmediata para personal interno y Centro de Operaciones).
- Correo electrónico dedicado de seguridad (seguridad@interafas, simulado), monitoreado por el equipo de analistas.
- Formulario interno de reporte de incidentes disponible en la Intranet institucional.
- Canal directo del Centro de Operaciones hacia el Ingeniero(a) de Control / Respondedor OT para anomalías del proceso físico.
- Canal de contacto responsable para investigadores externos de seguridad que identifiquen vulnerabilidades (divulgación coordinada).

4. Análisis y Priorización (Criterio PR02-34)

4.1 Triage Inicial

Al recibir una alerta o reporte, el analista en turno realiza una valoración preliminar dentro de los primeros 15 minutos, determinando si se trata de un falso positivo, un evento de seguridad sin mayor consecuencia, o un incidente que amerita la apertura formal de un caso y, en su caso, la activación del Plan conforme al numeral 1.6.

4.2 Validación del Incidente

La validación confirma, con evidencia técnica mínima (log, captura de tráfico, respuesta anómala del sistema), que el evento corresponde efectivamente a una actividad no autorizada y no a un comportamiento legítimo (p. ej., una prueba de carga programada o un mantenimiento no notificado). Esta validación es responsabilidad conjunta del analista de seguridad y, cuando el evento involucra a la zona operacional, del Ingeniero(a) de Control.

4.3 Determinación del Alcance

Una vez validado el incidente, el equipo técnico determina: los sistemas, cuentas y datos afectados; el vector de entrada inicial; si existe evidencia de movimiento lateral (p. ej., de la red IT hacia la red OT a través de /operations/gateway.php); y si el atacante mantiene acceso activo o persistencia al momento del análisis.

4.4 Clasificación y Priorización

Con base en el alcance determinado, el incidente se clasifica conforme a la tabla de severidad del numeral 1.4 y se prioriza utilizando una matriz de Impacto x Urgencia, otorgando prioridad máxima a todo incidente con componente OT confirmado o sospechado, con independencia de su impacto funcional aparente en el momento inicial.

Severidad	**Tiempo Máximo de Respuesta Inicial**	**Tiempo Máximo de Contención**
Nivel 1 — Bajo	8 horas hábiles	5 días hábiles
Nivel 2 — Medio	2 horas	24 horas
Nivel 3 — Alto	30 minutos	4 horas
Nivel 4 — Crítico/Emergencia	15 minutos	1 hora (acción inmediata de aislamiento OT)

4.5 Preservación de Evidencia Técnica y Cadena de Custodia

Toda evidencia recolectada durante el análisis (logs, capturas de tráfico, imágenes forenses, archivos de configuración, backups de firmware) se preserva conforme al siguiente procedimiento de cadena de custodia, a fin de mantener su validez probatoria y técnica:

1. Identificación: se etiqueta cada elemento de evidencia con folio de incidente, fecha/hora (UTC), sistema de origen y nombre de quien la recolecta.
2. Recolección: se obtiene una copia forense (hash SHA-256) antes de cualquier manipulación, priorizando evidencia volátil (memoria, conexiones activas) sobre evidencia no volátil.
3. Almacenamiento: se resguarda en repositorio forense de acceso restringido, con registro de acceso (log de custodia) para cada consulta posterior.
4. Transporte/Transferencia: toda entrega a terceros (p. ej., proveedor forense) se documenta con acuse de recibo y verificación de hash.

5. Disposición final: conforme a la política de retención de evidencia de INTERAFAS y a los requerimientos de autoridades, en coordinación con el Enlace Jurídico.

4.6 Escalamiento

El analista en turno escala de inmediato al Líder del CSIRT todo incidente clasificado como Nivel 3 o 4, o todo incidente de Nivel 2 que, tras 2 horas de análisis, no pueda ser contenido con los recursos del equipo técnico de guardia. El Líder del CSIRT, a su vez, escala a la Alta Dirección conforme a los tiempos y mecanismos establecidos en el numeral 8.

5. Contención (Criterio PR02-35)

La estrategia de contención de INTERAFAS equilibra tres objetivos que pueden entrar en tensión: la continuidad operativa del servicio de agua potable, la reducción del riesgo de propagación del incidente, y la preservación de evidencia técnica. La decisión sobre la estrategia a aplicar corresponde al Líder del CSIRT, en consulta con el Ingeniero(a) de Control cuando el incidente involucra activos OT, bajo el principio rector de que ninguna consideración de continuidad operativa o de preservación de evidencia puede anteponerse a la seguridad física.

5.1 Contención Inmediata (Corto Plazo)

- Aislamiento de red del sistema comprometido (segmentación o desconexión del segmento afectado), priorizando el aislamiento inmediato de la pasarela /operations/gateway.php ante cualquier evidencia de bypass del control de origen.
- Revocación o suspensión de credenciales y sesiones comprometidas (p. ej., invalidación forzada de PHPSESSID, rotación de la credencial de mantenimiento soporte.ot@interafas.local).
- Bloqueo perimetral de direcciones IP o rangos identificados como origen del ataque, y endurecimiento temporal de reglas de firewall/WAF.
- En escenarios OT: retorno manual e inmediato del parámetro físico afectado (p. ej., pressure_setpoint_bar) a su valor nominal de ingeniería (4.2 bar) y, de ser necesario, activación de los enclavamientos de seguridad física (SIS) independientes de la red de telemetría.

5.2 Contención Prolongada (Mediano Plazo)

- Aplicación de parches o mitigaciones temporales sobre el vector explotado, mientras se desarrolla y valida la remediación definitiva del numeral 6.
- Monitoreo reforzado y reglas de detección específicas (IOC/IOA) para identificar reintentos de explotación del mismo vector u otros relacionados dentro de la cadena de ataque.
- Mantenimiento de los sistemas comprometidos en un entorno aislado (cuarentena) cuando se requiera preservar evidencia adicional antes de proceder a la erradicación completa.
- Reautenticación obligatoria y forzada de todos los usuarios con posible exposición de credenciales, sin esperar a la conclusión completa del análisis forense.

6. Erradicación y Remediación (Criterio PR02-36)

La erradicación procede únicamente una vez contenido el incidente y concluida la recolección de evidencia necesaria, y tiene por objeto eliminar por completo la causa raíz y cualquier mecanismo de

persistencia dejado por el atacante, con base en los dictámenes técnicos del Informe de Seguridad Ofensiva.

6.1 Eliminación de Causas Raíz por Categoría de Vulnerabilidad

Categoría de Vulnerabilidad (ref. Informe de Seguridad Ofensiva)	**Acción de Erradicación**
Exposición de archivos residuales y directorios (Retos 01, 02, 04, 05)	Eliminación definitiva de artefactos residuales, deshabilitación de Options +Indexes, desactivación de display_errors en producción e incorporación de reglas de exclusión en el pipeline de despliegue.
Control de acceso y gestión de sesión (Retos 03, 06, 10, 11, 12)	Implementación de session_regenerate_id(true), validación de pertenencia por $_SESSION['user_id'] en todas las consultas de objeto, y eliminación de la lectura de rol desde cookies/parámetros del cliente.
Inyección y lógica de negocio (Retos 07, 08, 09, 13, 14)	Migración a consultas preparadas con PDO (ATTR_EMULATE_PREPARES=false), codificación de salida (htmlspecialchars), validación de rutas con realpath() y revalidación server-side de montos e INNER JOIN de relación proveedor-contrato.
Frontera IT/OT y gateway operacional (Retos 15, 16, 17)	Eliminación de la confianza en X-Forwarded-For para decisiones de autorización, segmentación real de red (VLAN/mTLS) y middleware de autenticación unificado en /operations/.
Cadena de suministro de firmware (Reto 18)	Revocación de la credencial heredada basada en SHA-1, migración a Argon2id/bcrypt, e implementación de verificación de firma digital asimétrica (Ed25519/RSA-PSS) en el instalador.
Exceso de privilegios y parámetros físicos (Retos 19, 20)	Segregación de funciones del rol maintenance, restricción de alcance a solo lectura diagnóstica, e implementación de límites de ingeniería (safety bounds) inmutables en el controlador.

6.2 Eliminación de Persistencia

- Revisión y eliminación de cuentas, tareas programadas, webshells o scripts no autorizados creados durante el incidente.
- Verificación de integridad de binarios y firmware frente a una línea base conocida (golden image), con especial atención al firmware del gateway RTU-GW-07.
- Rotación integral de credenciales y secretos que pudieron haber sido expuestos durante la cadena de ataque, incluyendo claves de base de datos y tokens de sesión.

Verificación técnica de erradicación ejecutada sobre INTERAFAS-LAB (comandos de validación, resultado de escaneo posterior): [INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]

6.3 Validación de Controles Antes de la Recuperación

Antes de autorizar el retorno a producción, el equipo técnico debe validar —mediante pruebas controladas análogas a las descritas en el Informe de Seguridad Ofensiva— que el vector explotado ya no es funcional, documentando el resultado como requisito de entrada a la fase de Recuperación (numeral 7). Esta validación es autorizada formalmente por el Líder del CSIRT.

7. Recuperación (Criterio PR02-37)

7.1 Restauración Segura de Sistemas

La restauración se realiza preferentemente a partir de respaldos limpios y verificados anteriores a la fecha estimada de compromiso, aplicando previamente todos los parches y controles derivados del numeral 6, nunca restaurando directamente sobre la infraestructura comprometida sin antes reconstruir el sistema operativo base cuando exista evidencia de persistencia a nivel de sistema.

7.2 Pruebas de Funcionamiento

- Pruebas funcionales de los módulos restaurados (portal ciudadano, APIs, pasarela de pago) en un entorno de preproducción antes de exponerlos públicamente.
- Pruebas de regresión de seguridad dirigidas específicamente al vector erradicado, replicando el procedimiento de comprobación documentado en el Informe de Seguridad Ofensiva.
- En el caso de OT: prueba escalonada y supervisada del proceso físico, iniciando en modo manual/local antes de restablecer el control remoto vía HMI, verificando que pressure_setpoint_bar y demás variables de proceso respeten los límites seguros de ingeniería.

7.3 Monitoreo Reforzado Post-Incidente

Durante un periodo no menor a 30 días naturales posteriores al restablecimiento del servicio, los sistemas afectados permanecen bajo monitoreo reforzado (umbrales de alerta reducidos, revisión diaria de logs por el analista asignado), a fin de detectar cualquier reincidencia o intento de reexplotación.

7.4 Criterios para Volver a la Operación Normal

- Confirmación documentada de erradicación completa de la causa raíz (numeral 6.3).
- Resultado satisfactorio de las pruebas funcionales y de seguridad del numeral 7.2.
- Autorización formal y conjunta del Líder del CSIRT y, en incidentes con componente OT, del Ingeniero(a) de Control.
- Ausencia de alertas de reincidencia durante al menos las primeras 48 horas del periodo de monitoreo reforzado.

7.5 Mecanismos de Rollback

Toda acción de remediación o restauración debe contar con un punto de reversión documentado (snapshot de configuración, respaldo de base de datos, copia de firmware previo validado). Si tras el restablecimiento se detecta una afectación funcional no prevista o evidencia de que la erradicación fue incompleta, el Líder del CSIRT puede ordenar el rollback inmediato al último estado estable conocido, reabriendo el caso en la fase de Contención.

8. Coordinación y Comunicación (Criterio PR02-38)

8.1 Flujo de Escalamiento Ejecutivo

El Líder del CSIRT informa a la Alta Dirección dentro de los tiempos establecidos en el numeral 1.6, utilizando un reporte ejecutivo breve (estado, severidad, impacto confirmado, acciones en curso), y convoca formalmente al Comité de Gestión de Incidentes de Ciberseguridad cuando el incidente alcanza

Nivel 3 o 4, comité del cual se desprende, para efectos de comunicación pública, el Comité de Crisis de Comunicación descrito en el documento 04.ApellidosNombre_PlanComunicacionCrisis.

8.2 Coordinación con el Equipo de Comunicación de Crisis

En cuanto un incidente alcanza Nivel 2 con probabilidad razonable de visibilidad pública, o Nivel 3/4 de manera automática, el Líder del CSIRT activa al Enlace de Comunicación de Crisis, proporcionándole el estado técnico validado (hechos confirmados vs. en investigación) que servirá de insumo para los mensajes por etapa definidos en el Plan de Comunicación de Crisis, evitando en todo momento que la comunicación pública revele detalles técnicos explotables (numeral 7.3 del documento 04).

8.3 Coordinación con Autoridades Competentes

- Notificación a la autoridad de protección de datos personales competente cuando se confirme el acceso no autorizado a datos de usuarios, conforme a los plazos regulatorios aplicables, a cargo del Enlace Jurídico y el Oficial de Protección de Datos.
- Notificación a la autoridad sectorial de agua y, en su caso, a protección civil, cuando el incidente involucre o ponga en riesgo la continuidad o seguridad física del proceso de bombeo y distribución.
- Coordinación con autoridades de ciberseguridad nacional/sectorial para intercambio de indicadores de compromiso (IOC) cuando el incidente pueda afectar a otros organismos operadores.

8.4 Coordinación con Terceros

El Líder del CSIRT activa a los terceros especializados (forensia digital, fabricante/integrador del gateway RTU, proveedor de conectividad) conforme al anexo de contactos de emergencia referido en el numeral 2, formalizando su participación mediante los acuerdos de confidencialidad y nivel de servicio previamente suscritos.

8.5 Coordinación Interna

Toda comunicación interna relacionada con el incidente (instrucciones al personal operativo, restricciones temporales de acceso, cambios en procedimientos) se canaliza a través de los mismos públicos y canales internos definidos en el documento 04.ApellidosNombre_PlanComunicacionCrisis, evitando la circulación de información técnica sensible fuera de los roles definidos en el numeral 2.

9. Playbooks Operativos (Criterio PR02-39)

A continuación se desarrollan cinco (5) playbooks operativos, derivados directamente de los escenarios de ataque observados y confirmados en INTERAFAS-LAB conforme al Informe Técnico de Seguridad Ofensiva, agrupando los veinte retos evaluados en cadenas de respuesta coherentes y ejecutables. Cada playbook sigue la estructura de fases de CISA/NIST SP 800-61 (Preparación; Detección y Análisis; Contención, Erradicación y Recuperación; Post-Incidente) e incluye disparador, responsables, acciones paso a paso, evidencia a recolectar, medidas de contención, recuperación y criterios de cierre.

PB-01 — Exposición de Información Sensible y Artefactos Residuales en el Portal Web

Escenarios de origen: Retos OPEN-DOOR, LOOK-CLOSER, OLD-MEMORIES y TOO-MUCH-INFO (archivos .zip/.bak residuales, manifiestos de compilación expuestos, divulgación de información mediante errores).

Disparador (Trigger)

Detección, mediante monitoreo de logs del servidor web o reporte externo, de accesos repetidos y secuenciales a rutas no enlazadas públicamente (p. ej., patrones de fuerza bruta de extensiones .bak/.old/.zip), o recepción de una alerta por exposición de un archivo de respaldo o manifiesto de compilación en el directorio público.

Responsables

- Analista de Seguridad (ejecución técnica) — Administrador de Infraestructura (remediación de configuración) — Líder del CSIRT (validación y cierre).

Acciones Paso a Paso

1. Preparación: verificar que exista línea base de los directorios y archivos públicos autorizados del portal.
2. Detección: confirmar en los logs de Apache el patrón de acceso anómalo (código 200 sobre rutas no documentadas) y el archivo o recurso específico expuesto.
3. Análisis: determinar qué información contenía el artefacto expuesto (metadatos de build, credenciales, código fuente, estructura interna) y si fue descargado por una IP externa no autorizada.
4. Contención: retirar de inmediato el archivo o recurso del document root; deshabilitar temporalmente Options +Indexes en el directorio afectado.
5. Erradicación: aplicar las reglas de exclusión de despliegue y el bloqueo de extensiones sensibles (ver numeral 6.1); purgar cualquier caché/CDN que haya servido el recurso.
6. Recuperación: validar mediante barrido de extensiones (análogo al Reto 04) que no existan artefactos residuales adicionales antes de cerrar el caso.

Medidas de Contención

- Retiro inmediato del recurso; deshabilitación de listado de directorios; bloqueo temporal de la IP de origen si se identifica actividad de enumeración activa.

Recuperación

- Reconfiguración permanente de Apache y del pipeline CI/CD; verificación de ausencia de artefactos residuales en un segundo barrido independiente.

Criterios de Cierre

El caso se cierra cuando el recurso ha sido retirado, la configuración corregida ha sido desplegada y validada, y no se identifican descargas adicionales del artefacto en las 48 horas posteriores a la contención.

PB-02 — Compromiso de Sesión y Acceso No Autorizado a Datos Ciudadanos

Escenarios de origen: Retos WHO-ARE-YOU, WRONG-ROLE, NOT-YOURS, HIDDEN-HISTORY y SECOND-ACCOUNT (fijación de sesión, escalada de rol, IDOR y BOLA sobre expedientes e historial de consumo).

Disparador (Trigger)

Alerta de acceso secuencial a identificadores de expediente o de cuenta por parte de una misma sesión (patrón de iteración numérica), reporte ciudadano de visualización de datos ajenos, o detección de una sesión que ejerce funciones administrativas sin el rol correspondiente registrado en base de datos.

Responsables

- Analista de Seguridad y Administrador de Bases de Datos (análisis e identificación de registros expuestos) — Oficial de Protección de Datos (evaluación de impacto a titulares) — Líder del CSIRT (declaración de severidad).

Acciones Paso a Paso

1. Preparación: contar con capacidad de consulta de logs de aplicación que incluyan PHPSESSID, usuario y objeto solicitado.
2. Detección: identificar en los logs la sesión y el rango de identificadores de expediente/cuenta consultados fuera del patrón normal de uso.
3. Análisis: determinar el número de registros de terceros potencialmente expuestos y si la sesión corresponde a un usuario legítimo o a una fijación de sesión previa (verificar si PHPSESSID fue emitido antes del login, conforme al Reto 10).
4. Contención: invalidar de inmediato la sesión comprometida; forzar cierre de sesión global de la cuenta afectada; bloquear temporalmente el endpoint si el volumen de acceso indica automatización.
5. Erradicación: desplegar la validación de pertenencia por $_SESSION['user_id'], la regeneración de ID de sesión post-login y la eliminación de la lectura de rol desde el cliente (numeral 6.1).
6. Recuperación: rotar PHPSESSID de todas las sesiones activas del sistema; notificar a los titulares de los expedientes/cuentas confirmadamente expuestos.

Medidas de Contención

- Invalidación de sesión y credenciales comprometidas; suspensión temporal del endpoint vulnerable si el riesgo de exfiltración masiva persiste.

Recuperación

- Despliegue de los controles de autorización a nivel de objeto; comunicación a usuarios afectados conforme al numeral 8.3; monitoreo reforzado del endpoint corregido.

Criterios de Cierre

El caso se cierra una vez desplegada y validada la corrección de autorización, notificados los titulares afectados identificados y confirmada la ausencia de nuevos accesos cruzados durante 72 horas de monitoreo reforzado.

PB-03 — Inyección de Código y Abuso de Lógica de Negocio

Escenarios de origen: Retos SILENT-ANSWER, STORED-WORDS, TOO-DEEP, PAYMENT-PATH y TRUSTED-SUPPLIER (SQL Injection ciega, Stored XSS, Path Traversal y manipulación de reglas de negocio de pago y contratación).

Disparador (Trigger)

Alertas del WAF/IDS por patrones de inyección SQL (operadores booleanos, comentarios SQL), ejecución de JavaScript no esperado reportada por un operador que revisa tickets ciudadanos, solicitudes con secuencias ../ en parámetros de descarga, o discrepancia contable entre el saldo registrado de una factura y el monto efectivamente recibido.

Responsables

- Analista de Seguridad y Administrador de Bases de Datos (SQLi) — Desarrollador(a) Backend (XSS, Path Traversal y lógica de negocio) — Área de Finanzas/Contraloría (validación de impacto en pagos) — Enlace Jurídico (impacto contractual en TRUSTED-SUPPLIER).

Acciones Paso a Paso

1. Preparación: habilitar registro detallado de consultas SQL en los endpoints de validación contractual y exportación de datos.
2. Detección: identificar en logs la presencia de condiciones booleanas inyectadas, payloads de script almacenados, rutas con ../ o transacciones de pago con monto inconsistente respecto al saldo registrado.
3. Análisis: determinar el alcance de la extracción por inferencia (tablas/columnas consultadas), los usuarios expuestos al Stored XSS, los archivos del sistema accedidos vía Path Traversal, y el importe real no cobrado o el contrato indebidamente validado.
4. Contención: deshabilitar temporalmente el endpoint vulnerable o aplicar una regla de WAF específica; revertir manualmente el estado "Pagado" de facturas liquidadas con monto inconsistente; suspender la validez del vínculo contractual indebidamente certificado.
5. Erradicación: migrar a consultas preparadas (PDO), aplicar codificación de salida (htmlspecialchars), sanitizar rutas con realpath()/basename(), y revalidar montos y relaciones contractuales en el servidor (numeral 6.1).
6. Recuperación: ejecutar pruebas de regresión específicas para cada vector (inyección booleana, payload XSS, traversal, pago parcial, vínculo cruzado) antes de reactivar el endpoint en producción.

Medidas de Contención

- Aislamiento del endpoint afectado; reversión manual de registros financieros o contractuales alterados; invalidación de contenido almacenado malicioso.

Recuperación

- Despliegue de consultas parametrizadas, codificación de salida y revalidación server-side; conciliación contable y jurídica de los registros afectados.

Criterios de Cierre

El caso se cierra cuando las correcciones han sido validadas mediante pruebas de regresión, se ha conciliado cualquier discrepancia financiera o contractual con el área correspondiente, y no se detectan nuevos intentos de explotación durante 5 días de monitoreo reforzado.

PB-04 — Pivote Lateral IT→OT y Compromiso de la Pasarela Operacional

Escenarios de origen: Retos BEHIND-THE-DESK, BEYOND-THE-WEB y EYES-ON-THE-PLANT (fuga de topología de red, bypass del gateway mediante X-Forwarded-For y acceso no autorizado a telemetría HMI).

Disparador (Trigger)

Alerta del IDS/IPS o del firewall perimetral por tráfico hacia /operations/gateway.php o rutas asociadas proveniente de direcciones IP externas a la subred operacional autorizada, especialmente cuando dicho tráfico incluye manipulación de cabeceras HTTP relacionadas con el origen de la conexión (p. ej., X-Forwarded-For).

Responsables

- Administrador de Infraestructura/Redes (contención perimetral) — Ingeniero(a) de Control / Respondedor OT (evaluación del impacto en el entorno operacional) — Líder del CSIRT (declaración de incidente de Nivel 3/4).

Acciones Paso a Paso

1. Preparación: mantener actualizado el mapa de segmentación IT/OT y las reglas de firewall que restringen el acceso a /operations/.
2. Detección: confirmar en los logs del gateway el acceso exitoso (200 OK) desde un origen no autorizado y la cabecera utilizada para evadir el control.
3. Análisis: determinar qué recursos de la vista HMI y del servicio de telemetría fueron consultados, y si se obtuvo visibilidad de variables de proceso o del canal de actualización de firmware.
4. Contención inmediata: aislar la pasarela /operations/gateway.php del segmento de red pública (desconexión o bloqueo perimetral estricto); invalidar cualquier sesión operacional activa iniciada desde el origen no autorizado.
5. Escalamiento: notificar de inmediato al Ingeniero(a) de Control para verificar, desde el propio Centro de Operaciones, que no se hayan recibido comandos o cambios de configuración no autorizados.
6. Erradicación: eliminar la confianza en X-Forwarded-For para decisiones de autorización, migrar a validación basada en el origen real de socket (REMOTE_ADDR) y segmentar el gateway en una red/VLAN dedicada con autenticación mTLS/VPN (numeral 6.1).
7. Recuperación: reactivar el acceso operacional únicamente tras validar, mediante prueba controlada, que el bypass de cabecera ya no es explotable.

Medidas de Contención

- Aislamiento inmediato del gateway del segmento público; invalidación de sesiones operacionales activas; monitoreo reforzado de toda la subred OT.

Recuperación

- Segmentación real de red con autenticación fuerte (mTLS/VPN); middleware de autorización unificado en /operations/; prueba de penetración dirigida antes de reabrir el acceso.

Criterios de Cierre

El caso se cierra cuando se confirma, mediante prueba técnica, que el bypass de cabecera ya no es funcional, se ha verificado con el Ingeniero(a) de Control que no hubo alteración de parámetros de proceso, y la segmentación definitiva ha sido implementada y validada.

PB-05 — Manipulación de Firmware y Parámetros Físicos — Impacto Catastrófico en OT

Escenarios de origen: Retos TRUST-THE-PACKAGE, CHAIN-REACTION y NOW-YOU-CONTROL (credencial heredada con hash débil, carga de firmware no firmado, encadenamiento de privilegios de mantenimiento y alteración de pressure_setpoint_bar hasta CATASTROPHIC STATE). Este playbook es de activación automática en Nivel 4 (Emergencia) conforme al numeral 1.4.

Disparador (Trigger)

Alarma crítica del HMI/SCADA por valores de presión, caudal o disponibilidad fuera de los límites normales de operación; carga de un paquete de firmware o archivo de configuración en el gateway RTU-GW-07 no correspondiente a un cambio de mantenimiento programado; o uso de la credencial de mantenimiento fuera de la ventana de servicio autorizada.

Responsables

- Ingeniero(a) de Control / Respondedor OT (acción inmediata, con autoridad para actuar sin esperar autorización previa cuando exista riesgo físico) — Líder del CSIRT (declaración de Nivel 4 y coordinación) — Dirección General (notificación inmediata) — Enlace de Comunicación de Crisis y Enlace Jurídico (activación simultánea).

Acciones Paso a Paso

1. Preparación: mantener disponibles y probados los mecanismos de enclavamiento físico de seguridad (SIS) independientes de la red de telemetría, y una copia de referencia (golden image) del firmware legítimo del RTU-GW-07.
2. Detección: identificar en el HMI la transición de estado hacia condición crítica y correlacionarla con el registro de carga de configuración/firmware más reciente en /operations/updates/.
3. Contención física inmediata (prioridad absoluta): el Ingeniero(a) de Control revierte manualmente el parámetro físico afectado a su valor nominal de ingeniería (p. ej., pressure_setpoint_bar = 4.2 bar) y, si el HMI no responde con confiabilidad, activa el enclavamiento de seguridad físico/local del proceso, sin esperar validación remota.
4. Contención lógica: aislamiento inmediato del canal de actualización de firmware (/operations/updates/) y revocación de la credencial de mantenimiento comprometida; suspensión de la sesión con rol maintenance que ejecutó el encadenamiento de activos.
5. Análisis forense: preservar el paquete de firmware cargado, su hash SHA-256, el manifiesto de actualización y los registros de autenticación Basic utilizados, conforme a la cadena de custodia del numeral 4.5.
6. Erradicación: restaurar el firmware del RTU-GW-07 desde la golden image validada; revocar y reemitir credenciales de mantenimiento bajo bcrypt/Argon2id; implementar verificación de firma digital asimétrica y límites de ingeniería inmutables (safety bounds) en el validador de configuración (numeral 6.1).
7. Recuperación supervisada: restablecer el control remoto de forma escalonada, iniciando en modo manual/local y verificando estabilidad del proceso durante un periodo de observación continua antes de restituir el control vía HMI (numeral 7.2).
8. Notificación: activación inmediata y simultánea del Plan de Comunicación de Crisis en su etapa de reconocimiento inicial (numeral 6.1 del documento 04), y notificación a protección civil/autoridad sectorial conforme al numeral 8.3.

Medidas de Contención

- Reversión manual inmediata del parámetro físico; activación de enclavamientos de seguridad independientes; aislamiento del canal de actualización de firmware; revocación de credenciales de mantenimiento.

Recuperación

- Restauración de firmware desde golden image firmada; recuperación escalonada y supervisada del control remoto; monitoreo reforzado continuo durante al menos 30 días (numeral 7.3).

Criterios de Cierre

El caso se cierra únicamente con la autorización conjunta de la Dirección General y el Ingeniero(a) de Control, una vez confirmado que: el parámetro físico se mantiene estable dentro de los límites de ingeniería durante el periodo de observación; el firmware restaurado cuenta con firma digital válida; la credencial comprometida ha sido revocada y reemplazada; y se ha completado el informe de cierre conforme al numeral 10.

10. Post-Incidente y Mejora (Criterio PR02-40)

10.1 Procedimiento de Cierre

Todo incidente se cierra formalmente mediante la autorización del Líder del CSIRT (o, en incidentes Nivel 4, de la Dirección General conforme al playbook PB-05), una vez verificado el cumplimiento de los criterios de cierre específicos del playbook aplicado y concluida la recuperación conforme al numeral 7.4. El cierre se registra en el Sistema de Gestión de Tickets de Seguridad bajo el folio del incidente, con fecha, hora y responsable de autorización.

10.2 Estructura del Informe Final

- Resumen ejecutivo del incidente (qué ocurrió, severidad final, impacto confirmado).
- Cronología detallada (timeline) desde la detección hasta el cierre, con folios y horas de cada fase.
- Vector de entrada, causa raíz y cadena de ataque (referenciando los hallazgos técnicos del Informe de Seguridad Ofensiva).
- Acciones de contención, erradicación y recuperación ejecutadas, y playbook(s) aplicado(s).
- Evidencia recolectada y estado de la cadena de custodia.
- Impacto final (datos, operación, financiero, reputacional) y notificaciones realizadas a autoridades/titulares.
- Lecciones aprendidas y acciones correctivas (numeral 10.4).
- Métricas de respuesta del incidente (numeral 10.5).

10.3 Reunión de Lecciones Aprendidas

Dentro de los 10 días hábiles posteriores al cierre del incidente, el Líder del CSIRT convoca a una reunión de lecciones aprendidas con la participación de todos los roles involucrados conforme al numeral 2, cuya agenda mínima comprende: (i) revisión cronológica del incidente; (ii) qué funcionó conforme al Plan y qué no; (iii) brechas identificadas en la preparación, detección o contención; (iv) propuestas de

mejora al Plan, a los playbooks o a los controles técnicos; y (v) asignación de responsables y fechas para cada acción correctiva.

10.4 Acciones Correctivas

Hallazgo / Brecha Identificada	Acción Correctiva	Responsable	Fecha Compromiso
[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[Rol responsable]	[Fecha]
[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[Rol responsable]	[Fecha]
[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[INSERTAR EVIDENCIA DEL LABORATORIO AQUÍ]	[Rol responsable]	[Fecha]

Nota: las filas de esta tabla deben completarse con los hallazgos reales identificados durante la ejecución de los playbooks en INTERAFAS-LAB y la reunión de lecciones aprendidas correspondiente.

10.5 Métricas de Respuesta

Métrica	Definición
MTTD (Mean Time to Detect)	Tiempo promedio transcurrido entre el inicio real del incidente y su detección por el CSIRT.
MTTA (Mean Time to Acknowledge)	Tiempo promedio entre la generación de la alerta y su reconocimiento/triage por un analista.
MTTC (Mean Time to Contain)	Tiempo promedio entre la validación del incidente y la aplicación efectiva de la primera medida de contención.
MTTR (Mean Time to Recover)	Tiempo promedio entre la contención y el restablecimiento de la operación normal conforme al numeral 7.4.
Tasa de reincidencia	Porcentaje de incidentes cerrados que presentan un evento relacionado dentro de los 30 días posteriores al cierre.
Cumplimiento de playbook	Porcentaje de pasos del playbook aplicable efectivamente ejecutados y documentados durante el incidente.

10.6 Seguimiento hasta la Resolución

El Coordinador de Mejora Continua del CSIRT (rol asignado por el Líder del CSIRT) da seguimiento mensual al estado de las acciones correctivas registradas en el numeral 10.4 hasta su resolución completa, reportando el avance a la Alta Dirección y actualizando, cuando corresponda, el presente Plan y sus playbooks operativos, de forma que el ciclo de mejora continua quede documentado y disponible para la siguiente activación del Plan.